

Penetration Testing Report

Report For:

Company: Metasploitable3

Task: Security Assessment for Metasploitable3

Prepared By: Christian Jacobe

Email: #####

Contact: #####

Table Of Contents

1. Executive Summary	4
1.1. Objective	4
1.2. Scope.....	4
1.3. Testing Period	4
1.4. Key Findings	4
1.5. Overall Security Rating	4
2. Methodology	5
2.1. Testing Approach	5
2.2. Tools used	5
2.3. Phase of Testing.....	5
3. Finding & Exploitation Results	6
3.1. Vulnerabilities Discovered.....	6
4. Impact Assessment	7
5. Recommendation & Remediation	8
6. Conclusion	8
6.1. Summary of Findings.....	8
6.2. Security Improvements	8
6.3. Next Steps	8
7. Appendix	8
7.1. Screenshots	9

Document Control

Client Confidentiality

This document contains Client Confidential information and may not be copied without written permission.

Proprietary Information

The content of this document is considered proprietary information and should not be disclosed outside of the recipient organization's network.

Christian Jacobe gives permission to copy this report for the purposes of disseminating information within your organization or any regulatory agency.

Document Version Control

Issue No.	Issue Date	Issued By	Change Description
0.1	03/02/2025	Christian Jacobe	Draft for Internal Review Only

1. Executive Summary

Objective: The primary objective of this penetration test was to conduct a comprehensive security assessment to identify vulnerabilities, evaluate security posture, and ensure compliance with relevant security standards.

Scope: Web applications, Server configurations, Network infrastructure, Third-party libraries and components

Testing Period: Start Date: 03/01/2025 **End Date:** 03/01/2025

Key Findings:

- **CVSS 9.0 (Critical)** - Privilege Escalation via Docker Privileged Container with Root Access
- **CVSS 7.0(High)** – Unreal IRCD3.2.8.1 Backdoor

Overall Security Rating:

The security posture of the tested environment is assessed to be at a **high-risk level**. The presence of both critical and high-severity vulnerabilities indicates that there are significant security issues that need to be addressed promptly. Continuous monitoring, regular updates, and adherence to best practices are recommended to mitigate identified risks and enhance overall security.

2. Methodology

2.1. Testing Approach

- **Type of testing:** Black box testing
- **Rationale:** This approach was chosen to simulate an external attacker's perspective with no prior knowledge of the system's internals.

2.2. Tools-used

- **Metasploit:** An exploitation framework used for developing, testing, and executing exploits against target systems.
- **Nessus:** A vulnerability scanning tool that helps identify vulnerabilities in systems and applications.
- **Nmap:** A network scanning and enumeration tool used to discover hosts and services on a network.

2.3. Phase Of Testing

1. **Reconnaissance** - Information gathering.
2. **Scanning & Enumeration** - Identifying vulnerabilities.
3. **Exploitation** - Attempting to gain access.
4. **Post-Exploitation** - Privilege escalation, persistence, data extraction.
5. **Reporting & Remediation** - Documentation and recommendations

3. Findings and Exploitation Results

Vulnerability Name: Privilege Escalation via Docker Privileged Container with Root Access

Description: Running a Docker container with privileged access and root permissions poses a significant security risk. Privileged containers have elevated privileges and direct access to the host system, which can be exploited for privilege escalation. In this case, the root access was gained because the user **boba_fett** was added to the Docker group, allowing them to create a privileged container without requiring sudo permissions. Attackers can gain root access on the host system, execute arbitrary commands, and compromise the entire system.

Risk Level: Critical

CVSS Score: 9.0 (Critical)

Vector: CVSS:3.1/AV:L/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H

Exploit Used: Exploitation of Docker privileged mode and root access

Vulnerability: CWE-284: Improper Access Control

Endpoints: Docker containers running in privileged mode with root access

Outcome: The vulnerability allows attackers to gain root access on the host system, execute arbitrary commands, and compromise the entire system. It is crucial to avoid running containers in privileged mode unless necessary and to use specific capabilities instead of full privileged access. Additionally, ensure that users added to the Docker group are trusted and have minimal privileges.

References:

- **CVE-2019-5736:** A well-known Docker privilege escalation vulnerability that allows attackers to gain root access on the host system:
 - CVE Details: CVE-2019-5736
 - Official Writeup: OpenWall Announcement
- **Docker Security Documentation:** Official Docker documentation provides best practices and security guidelines to mitigate privilege escalation vulnerabilities:
 - Docker Security Best Practices: Docker Security
- **Common Vulnerability Scoring System (CVSS) v3.1:** Official CVSS documentation from the Forum of Incident Response and Security Teams (FIRST):
 - CVSS v3.1 Documentation: FIRST CVSS

Vulnerability Name: Unreal IRCd 3.2.8.1 Backdoor

Description: The UnrealIRCd 3.2.8.1 backdoor is a critical vulnerability that allows remote attackers to execute arbitrary commands on the affected server. This backdoor was maliciously added to the UnrealIRCd 3.2.8.1 download archive, and it poses a significant risk to the security of the system.

Risk Level: High

CVSS Score: 7.5 (High)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:P/I:P/A:P

Exploit Used: Metasploit (exploit/unix/irc/unreal_ircd_3281_backdoor)

Vulnerability: CWE-78: Improper Neutralization of Special Elements used in an OS Command ('OS Command Injection')

Endpoints: Affected IRC server running UnrealIRCd 3.2.8.1 (172.16.16.131)

Outcome: The vulnerability allows remote attackers to execute arbitrary commands on the server, leading to potential full system compromise. It is crucial to upgrade to a secure version of UnrealIRCd and ensure the integrity of downloaded software packages.

References:

- CVE-2010-2075: A well-known backdoor in UnrealIRCd 3.2.8.1:
- CVE Details: CVE-2010-2075
- Official Writeup: OpenWall Announcement
- Metasploit Module: Exploit for UnrealIRCd 3.2.8.1 Backdoor:
- Rapid7 Vulnerability & Exploit Database: UnrealIRCd Backdoor

4. Impact Assessment

Issue	Potential Consequences	Business Impact	Exploitability Score
Privilege Escalation via Docker Privileged Container with Root Access	Gain root access on the host system, execute arbitrary commands, and compromise the entire system.	Critical	9.0 (Critical)
UnrealIRCd 3.2.8.1 Backdoor	Remote attackers can execute arbitrary commands on the server, leading to potential full system compromise.	High	7.5 (High)

5. Recommendation and Remediation

Issue	Fixes	Best Practices
Privilege Escalation via Docker Privileged Container with Root Access	Avoid running containers in privileged mode. Use specific capabilities instead.	Ensure minimal privileges for users added to the Docker group. Regularly review and update security policies. Do not add users to the Docker group without careful consideration. Require sudo permissions when creating containers.
UnrealIRCd 3.2.8.1 Backdoor	Upgrade to a secure version of UnrealIRCd. Verify the integrity of downloaded software packages.	Regularly check for updates and security advisories. Implement strict download and verification processes for software packages.

6. Conclusion

Summary of Findings:

- **Privilege Escalation via Docker Privileged Container with Root Access:** High risk of gaining root access on the host system, leading to potential system compromise and unauthorized execution of commands. (CVSS: 9.0 - Critical)
- **UnrealIRCd 3.2.8.1 Backdoor:** Remote attackers can execute arbitrary commands on the server, leading to potential full system compromise. (CVSS: 7.5 - High)

Security Improvements Needed:

- **Privilege Escalation via Docker Privileged Container with Root Access:**
 - **Fixes:** Avoid running containers in privileged mode. Use specific capabilities instead.
 - **Best Practices:** Ensure minimal privileges for users added to the Docker group. Regularly review and update security policies. Do not add users to the Docker group without careful consideration. Require sudo permissions when creating containers.
- **UnrealIRCd 3.2.8.1 Backdoor:**
 - **Fixes:** Upgrade to a secure version of UnrealIRCd. Verify the integrity of downloaded software packages.
 - **Best Practices:** Regularly check for updates and security advisories. Implement strict download and verification processes for software packages.

Next Steps:

- **Continuous Monitoring:** Implement ongoing monitoring for vulnerabilities and security incidents.
- **Security Training:** Conduct regular security training for development and operations teams.
- **Retesting:** Perform periodic security testing to identify and address new vulnerabilities.

7. Appendix

7.1. Screenshots

Unreal IRC Shell Access via Metasploit

```
[*] Command shell session 1 opened (172.16.16.132:4444 -> 172.16.16.131:39968) at 2025-03-01 21:39:00 -0500  
whoami  
boba_fett  
id boba_fett  
uid=1121(boba_fett) gid=100(users) groups=100(users),999(docker)
```

Root access via Docker for modifying parent machine files

```
7_01_diamonds  
boba_fett@metasploitable3-ub1404:/opt/unrealircd/Unreal3.2$ docker exec -it container /bin/bash  
ainer /bin/bash cont  
root@499a253f2a62:/# whoami  
whoami  
root  
root@499a253f2a62:/#
```

Sudo access for boba_fett

```
root@499a253f2a62:~# exit  
exit  
exit  
boba_fett@metasploitable3-ub1404:/opt/unrealircd/Unreal3.2$ sudo -i  
sudo -i  
root@metasploitable3-ub1404:~#
```